
🔍 1. What is a SOC, and what does it do?

Answer:

A Security Operations Center (SOC) is a centralized unit that deals with security issues at the organizational and technical level. It monitors, detects, investigates, and responds to cyber threats using a combination of technology solutions and a strong set of processes.

💡 2. What is the role of a SOC Analyst?

Answer:

A SOC Analyst monitors security tools and dashboards, investigates alerts, performs triage, and escalates incidents as needed. The goal is to detect threats early and coordinate responses to reduce damage.

🔍 3. What is a SIEM, and why is it important in a SOC?

Answer:

A SIEM (Security Information and Event Management) tool collects, aggregates, and analyzes logs from various sources to detect suspicious activities. It is the backbone of SOC operations, helping analysts monitor real-time alerts and perform historical analysis.

📊 4. What are common sources of logs used in a SOC?

Answer:

- Firewall logs
 - IDS/IPS logs
 - Web server logs
 - Antivirus logs
 - Windows event logs
 - Authentication logs (e.g., Active Directory)
-

🌪️ 5. What is the difference between a threat, a vulnerability, and a risk?

Answer:

- **Threat:** A potential cause of an unwanted incident (e.g., malware, hacker)
- **Vulnerability:** A weakness that could be exploited (e.g., unpatched software)
- **Risk:** The potential for loss or damage when a threat exploits a vulnerability

6. What is an Indicator of Compromise (IOC)?

Answer:

An IOC is evidence that a system may have been breached. Examples include:

- Unusual outbound network traffic
- Strange logins at odd hours
- Changes in file hashes
- Known malicious IPs or domains

📌 7. How would you investigate a phishing email report?

Answer:

1. Check the sender's address and email headers.
2. Analyze any attachments or URLs in a sandbox.
3. Search for similar reports in the ticketing system or threat feeds.
4. Look for users who clicked the link or entered credentials.
5. Contain affected accounts and educate users.

🔐 8. What is the MITRE ATT&CK framework?

Answer:

MITRE ATT&CK is a knowledge base of adversary tactics and techniques based on real-world observations. It helps SOC teams understand, detect, and respond to specific stages of cyberattacks.

🌐 9. What's the difference between IDS and IPS?

Answer:

- **IDS (Intrusion Detection System):** Monitors and alerts on suspicious activity.
- **IPS (Intrusion Prevention System):** Monitors and blocks suspicious traffic in real-time.

🔧 10. What are some common ports and their services?

Answer:

- Port 80 – HTTP
- Port 443 – HTTPS
- Port 22 – SSH

- Port 21 – FTP
 - Port 25 – SMTP
 - Port 3389 – RDP
-

11. What would you do if you saw multiple failed login attempts?

Answer:

- Check the source IP address.
 - Determine if the user exists and if the attempts are legitimate.
 - Correlate with other indicators (geolocation, timing, behavior).
 - If it looks like brute force, block the IP and alert the user.
-

12. What steps are involved in incident response?

Answer:

1. **Detection** – Identify suspicious activity.
 2. **Analysis** – Investigate the scope and impact.
 3. **Containment** – Prevent further damage.
 4. **Eradication** – Remove malicious artifacts.
 5. **Recovery** – Restore systems.
 6. **Lessons Learned** – Update processes.
-

13. How do you prioritize alerts in a SOC?

Answer:

Based on severity, asset criticality, and impact. High-severity alerts on critical assets (like domain controllers) get immediate attention, while low-priority events may be logged for later review.

14. What is lateral movement in cybersecurity?

Answer:

Lateral movement is when an attacker, after gaining initial access, moves through a network to find and compromise more systems or data.

15. What is the Cyber Kill Chain?

Answer:

A framework developed by Lockheed Martin outlining stages of a cyberattack:

1. Reconnaissance
 2. Weaponization
 3. Delivery
 4. Exploitation
 5. Installation
 6. Command & Control
 7. Actions on Objectives
-

◆ **Basic/Level 1 Questions**

1. What is the role of a SOC Analyst (L1)?

Answer: An L1 SOC Analyst monitors alerts, performs initial triage, filters out false positives, and escalates true positives to L2 for further analysis.

2. What tools are commonly used in a SOC?

Answer:

- SIEM (Splunk, QRadar, ArcSight)
 - IDS/IPS (Snort, Suricata)
 - EDR (CrowdStrike, SentinelOne)
 - Threat Intel (VirusTotal, OTX, MISP)
-

3. How do you distinguish a false positive?

Answer:

By analyzing log context, behavior patterns, known safe IPs/domains, and user activity. If no malicious indicators are present, it may be a false positive.

4. What are the key log sources in a SOC?

Answer:

- Windows Event Logs
 - Firewall logs
 - VPN logs
 - Endpoint logs
 - DNS logs
 - Web proxy logs
-

◆ Intermediate/Level 2 Questions

5. How would you investigate lateral movement?

Answer:

- Review logs from the suspected host
 - Check for remote desktop (RDP) or PsExec activity
 - Monitor account logins on other systems
 - Look for abnormal logon times or locations
 - Check for credential dumping tools
-

6. Explain the MITRE ATT&CK TTPs.

Answer:

- **Tactics:** Why an attacker does something (e.g., Persistence)
- **Techniques:** How they do it (e.g., Registry Run Keys)
- **Procedures:** Real-world examples of technique usage (e.g., APT28 using PowerShell scripts)

7. How do you respond to a ransomware attack?**Answer:**

1. Isolate infected machines
2. Identify strain via IOCs
3. Block C2 traffic
4. Notify stakeholders
5. Wipe/recover systems from backups
6. Conduct root cause analysis

8. What is a correlation rule in SIEM?**Answer:**

A rule that identifies patterns across multiple log sources to detect suspicious activity. Example: Multiple failed logins + successful login + privilege escalation = potential compromise.

9. How do you track a phishing campaign within your organization?**Answer:**

- Use SIEM to identify similar emails (by sender/subject/headers)
- Search email gateway logs
- Analyze URLs/attachments
- Use threat intelligence to correlate IOCs
- Notify affected users, isolate infected endpoints

10. How would you tune a SIEM to reduce noise?**Answer:**

- Suppress alerts from known safe sources
 - Adjust threshold values
 - Exclude test environments
 - Use whitelisting and baselining
 - Update correlation rules for relevance
-

आपके द्वारा दिए गए शब्द – **Threat Hunting, Incident Response, Security Center**, और **SOC (Security Operations Center)** – सभी साइबर सुरक्षा (Cybersecurity) के महत्वपूर्ण पहलुओं से संबंधित हैं। नीचे इन सभी को विस्तार से समझाया गया है:

🔍 1. Threat Hunting (थ्रेट हंटिंग)

परिभाषा:

Threat Hunting एक proactive (सक्रिय) प्रक्रिया है जिसमें साइबर सुरक्षा विशेषज्ञ संभावित खतरों या हमलों को खोजते हैं, जो पारंपरिक सुरक्षा उपायों से छूट सकते हैं।

मुख्य तत्व:

- Indicators of Compromise (IOCs) की पहचान
- Behavioral analytics का उपयोग
- Hypothesis driven investigation
- Security Information and Event Management (SIEM) टूल्स का उपयोग (जैसे Splunk, QRadar)

उदाहरण:

मान लीजिए कि एक संगठन में अचानक से कुछ मशीनें दुर्भावनापूर्ण डोमेन से संपर्क करने लगती हैं, लेकिन कोई अलार्म नहीं बजता। Threat Hunter यह व्यवहार पहचान सकता है और जांच शुरू कर सकता है।

🛡️ 2. Incident Response (इंसीडेंट रिस्पॉन्स)

परिभाषा:

Incident Response वह प्रक्रिया है जिसमें साइबर हमले या सुरक्षा उल्लंघन (breach) के बाद संगठन तुरंत और प्रभावी ढंग से प्रतिक्रिया करता है।

Stages (NIST के अनुसार):

1. **Preparation:** योजना, नीति, और टूल्स तैयार करना।
2. **Identification:** समस्या की पहचान करना।
3. **Containment:** नुकसान को सीमित करना।
4. **Eradication:** खतरे को सिस्टम से हटाना।
5. **Recovery:** सिस्टम को वापस सामान्य स्थिति में लाना।
6. **Lessons Learned:** समीक्षा करना और सुधार लागू करना।

उदाहरण:

अगर किसी कर्मचारी का सिस्टम रैंसमवेयर से संक्रमित हो गया है, तो Incident Response टीम तुरंत उस सिस्टम को नेटवर्क से अलग करती है, बैकअप से डेटा बहाल करती है और जांच शुरू करती है।

🛡️ 3. Security Center (सिक््योरिटी सेंटर)

परिभाषा:

यह एक सामान्य शब्द है जो संगठन के भीतर एक केंद्रीकृत स्थान को संदर्भित करता है जहाँ से सुरक्षा कार्यों की निगरानी, प्रबंधन और समन्वय किया जाता है।

उदाहरण:

Microsoft Defender Security Center या Azure Security Center जैसी सेवाएं एक unified dashboard प्रदान करती हैं, जहां से सुरक्षा संबंधित सूचनाएं और नियंत्रण देखे जा सकते हैं।

🏢 4. SOC (Security Operations Center)

परिभाषा:

SOC एक डेडिकेटेड यूनिट है जो 24x7 निगरानी, विश्लेषण और प्रतिक्रिया देती है साइबर खतरों के लिए। इसमें सिक््योरिटी एनालिस्ट, इंजीनियर्स और मैनेजर्स होते हैं।

मुख्य कार्य:

- लॉग मॉनिटरिंग और एनालिसिस
- अलर्ट का प्रबंधन
- साइबर हमलों पर तुरंत प्रतिक्रिया
- SIEM और SOAR जैसे टूल्स का उपयोग

SOC Levels:

- **L1 Analyst:** बेसिक अलर्ट मॉनिटरिंग और एस्केलेशन
- **L2 Analyst:** गहराई से विश्लेषण और पुष्टि
- **L3 Analyst:** एडवांस थ्रेट एनालिसिस, थ्रेट हंटिंग, रूट कॉज़ अनालिसिस

उदाहरण:

SOC सेंटर किसी बैंक की सुरक्षा का केंद्र हो सकता है जहाँ पर हर ईमेल, लॉगिन, और नेटवर्क ट्रैफिक की निगरानी की जाती है।

🔗 आपस का संबंध:

Term	Nature	काम करता है
Threat Hunting	Proactive	संभावित खतरे खोजता है
Incident Response	Reactive	हमले के बाद प्रतिक्रिया करता है
Security Center	Centralized	सुरक्षा टूल्स और पॉलिसी को मैनेज करता है
SOC	Operational	थ्रेट्स की निगरानी और प्रतिक्रिया करता है

अगर आपको इन विषयों पर PPT, नोट्स, या वर्कफ़्लो डायराम चाहिए हों तो बताएं — मैं बना सकता हूँ।

SOC Levels: L1, L2, and L3 Explained

In a SOC team, analysts are categorized into different levels based on their experience, responsibilities, and technical skills:

✔ L1 – Level 1 (Tier 1) SOC Analyst – First Responder

Role: Monitor, detect, and escalate.

Responsibilities:

- 24/7 monitoring of security alerts (via SIEM, EDR, etc.)
- Triage and classify alerts (e.g., false positives vs. real threats)
- Follow predefined playbooks/runbooks
- Escalate incidents to L2 if needed
- Basic investigation (IP, hash, URL lookups)
- Generate daily reports and ticketing

Example Task:

Noticing a login attempt from a suspicious IP address and escalating it to L2 after basic validation.

✔ L2 – Level 2 (Tier 2) SOC Analyst – Incident Responder

Role: Analyze, investigate, and contain threats.

Responsibilities:

- Deep-dive investigation of escalated incidents
- Correlate multiple alerts and data sources
- Conduct malware and packet analysis

- Handle containment actions (e.g., isolate infected systems)
- Work with threat intel to identify TTPs
- Assist in root cause analysis (RCA)
- Update and improve detection rules/playbooks

Example Task:

Analyzing a phishing email that led to malware download, performing forensics, and isolating affected endpoints.

✓ L3 – Level 3 (Tier 3) SOC Analyst – Threat Hunter / Expert

Role: Advanced analysis, threat hunting, strategy.

Responsibilities:

- Proactive threat hunting (searching for hidden threats)
- Reverse engineering malware
- Develop and tune detection rules (e.g., YARA, Sigma)
- Incident response leadership during major breaches
- Develop new playbooks and procedures
- Mentor L1 and L2 teams
- Coordinate with Red Team / Blue Team exercises

Example Task:

Hunting for signs of APT behavior in the environment using behavior analytics and threat intelligence.

📊 SOC Tier Comparison Table

Feature	L1 Analyst	L2 Analyst	L3 Analyst
Experience	0–2 years	2–5 years	5+ years
Focus	Alert monitoring & triage	Incident response & analysis	Threat hunting & advanced response
Tools Used	SIEM, ticketing tools	EDR, sandbox, forensic tools	Threat intel, YARA, custom scripts
Actions	Escalate or close tickets	Investigate, contain, document	Hunt, respond, lead investigations